

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Operator of custody, vault, warehouse, redemption, or pooled-asset product
DPO or similar function	Controller DPO or privacy contact
Repository evidence	Consumers/VAULTS_BIZ; custodyClient.js; shycam; shywire; patent/mainhub/dp

Name of the Processing

Internal name: Shyware Commodity Custody / Vaults DPIA

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category	Sensitivity
1	Custody account commitment	Holder, redeemer, issuer, or warehouse commitment	Medium/High
2	Redemption/issuance record	Asset, amount, redemption request, custody action	Financial/prop
3	KYB/KYC data	Warehouse owner, beneficial owner, customer verification	High
4	Camera/liveness proof	Inventory, liveness, warehouse proof, attestation evidence	Medium/High

Purposes of the Processing Support pooled-asset custody, issuance, redemption, inventory attestation, warehouse verification, audit, fraud prevention, and dispute resolution.

ANALYSIS OF THE PROCESSING

Lawfulness and Minimisation

Customer controllers must assess property, custody, consumer-protection, financial, and warehouse regulations. Camera or IoT proofs should avoid incidental capture of workers, visitors, and unrelated property.

Mainhub Patent Alignment

The Mainhub patent architecture can reduce canonical-state linkage between holder identity and custody/redemption records where two-list writes are used. It does not remove property-law, custody, dispute, camera/IoT, warehouse, KYB/KYC, or redemption audit risks. Custody deployments must separately govern real-world asset evidence, operator access, and legal process.

Authority Partition This is a count-match embodiment. Four structurally separated parties are required:

Authority	Role
Auth (Cognito)	Account layer; always required; gates access
IDV/KYB provider (Didit or KYB provider)	Verifies holder identity and beneficial ownership
Eligibility authority (warehouse operator or custody administrator)	Determines lot and redemption eligibility; manages custody
Reconciling authority	Off-chain linkage store + sealer keys

Dual co-authorization enforcement (Claim 2): The validation layer must reject single-signature rescission transactions. **VERIFIED (run 26369476939):** *DUAL_COSIG section passes 379/379 — unauthenticated + valid token → 401; authenticated + no token → 400; both co-signatures → 200, countMatch preserved.*

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The custody/vault pattern may be proportionate where ownership, redemption, conservation, and audit evidence must be preserved without publishing unnecessary identity–asset linkage in canonical state. Protected linkage should be limited to custody, redemption, dispute, fraud, or lawful-access purposes. Production should wait until custody role allocation, warehouse evidence, KYB/KYC, payment, retention, and redemption workflows are fixed.

RISK ASSESSMENT AND MANAGEMENT

#	Risk	Required Follow-up
1	Property/financial profiling	Minimize holder identifiers and public linkability
2	KYB/KYC overcollection	Define provider role, retention, and transfer posture
3	Camera/IoT incidental surveillance	Add capture boundaries, retention, and access controls
4	Redemption dispute harm	Define audit, correction, and dispute workflow

DPIA Audit Findings

This DPIA is the audit record for commodity custody and vault deployments. Before production, the DPIA must identify the provider partition across KYB/KYC or identity provider,

warehouse/custody operator, protected linkage store, reconciling authority, canonical commit authority, payment/settlement provider, and telemetry/support providers. Canonical-state unlinkability does not reduce obligations for ownership records, redemption, audit, dispute handling, fraud controls, or physical custody evidence. The software evidence for the core kernel may be complete while custody law, role allocation, retention, lawful-access, and redemption controls still need to be fixed for this domain.

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** (`patent/mainhub/dpia/source/COM` published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production. Template in Compliance Guide §Operator Obligations.
- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that `eligibility_authority_key` $\neq$ `reconciling_authority_key` $\neq$ `auth_key`.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment

The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while custody, redemption, warehouse evidence, lawful-access, KYB/KYC, payment, or dispute-workflow choices still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
Ownership or redemption dispute exposure	Custody records, redemption policy, audit logs, and dispute procedure
KYB/KYC provider breach	Subprocessor review, transfer controls, retention limits, and provider matrix
Physical custody evidence exposure	Sensor/camera minimization, access controls, and retention policy
Fraud or lawful-access overreach	Typed adverse actions, audit logs, legal review, and dual-control requirements
Provider consolidation	Provider matrix for identity, warehouse, payment, linkage, reconciling, and support

INVOLVEMENT OF INTERESTED PARTIES

Privacy counsel, custody/warehouse operators, payment or settlement stakeholders, security, and customer compliance teams should review this DPIA before production. Data subject or customer representative consultation may be appropriate where retail customers, physical redemption, or dispute handling is material.

CONCLUSION AND DECISION

Draft decision: Separate DPIA required before production vault/custody launch.